/

جامعة التقنية والعلوم التطبيقية
University of Technology and Applied Sciences
عبري
Ibri

مسقط
العاصمة العربية الرقمية
Muscat Arab Digital Capital
2022

رؤية عُمان 2040
نتقدم بثقة
Moving Forward with Confidence

COLLEGE OF COMPUTING AND INFORMATION SCIENCES

FINAL EXAMINATION: SEMESTER - I (Fall-2023)

Course Code & Title:	CSSY1208 – Introduction to Information Security		
Date	**Time**	**Duration**	**Total Marks**
10/1/2024	9:00-11:00 Am	2 Hours	40 Marks

STUDENT DETAILS

Student ID.		Department	Information Technology		
Student Name				System Number	
Specialization		Level		Section Number	

A

INSTRUCTIONS TO CANDIDATES

1. Do not open this question paper until the invigilator tells you to do so.
2. Answer the questions in the space provided by using **PEN** only.
3. Use of GSM (or mobile phones) and any other electronic gadgets inside the examination hall is **NOT** allowed.
4. Copying, Cheating and any kind of malpractices in the examination hall are strictly prohibited. Action will be taken as per **UTAS** By-laws.
5. Use last blank sheet for calculations. (Extra sheets are not allowed)
6. Students should bring their own pencils, pens, erasers, rulers, calculators, and any other tools required for the exam.

FOR DEPARTMENT USE ONLY

SECTION – A Theory (12 × 0.5 = 6 marks)				SECTION – B Theory (5× 2 = 10 marks)		SECTION – C Theory (6 x 4 = 24 marks)		Grand Total (40)	Grand Total (In Words)
1		7		1		1			
2		8		2		2			
3		9		3		3			
4		10		4		4			
5		11		5		5			
6		12		6		6			
Total				Total		Total			

Examiner Name **Moderator Name**

Section A [Multiple Choice Questions] Answer All [12 x 0.5 = 6 Marks]

1. **Which of the following is NOT a form of network-oriented Access Control List (ACL)?**
   a. IP addresses
   b. MAC addresses
   c. Email content
   d. Ports
2. **In UNIX-like operating systems, which part of the file permissions is represented by "rwx rwx rwx" ?**
   a. File creation date, modification date, and access date
   b. File size, file type, and file owner
   c. User, group, and other permissions
   d. File name, file path, and file extension
3. **Why are logs essential in computing environments and investigations?**
   a. Logs help in speeding up computer performance
   b. Logs provide a history of activities for auditing and investigations
   c. Logs secure sensitive data on systems
   d. Logs enable automatic updates for operating systems
4. **Which one of the following events is NOT recorded by the logging mechanism?**
   a. Software errors
   b. Hardware failures
   c. Users logging in or out
   d. Displaying the desktop background
5. **In symmetric encryption methods, which challenge appears due to using the same key for both encryption and decryption?**
   a. Key production issue
   b. Key exchange issue
   c. Key authorization issue
   d. Key authentication issue
6. **_____ prevents the sender from denying that he or she sent the message.**
   a. Buffer overflow
   b. SQL injection
   c. Reconnaissance
   d. Non of them

7. **What is the primary goal of a social engineer?**

a. Hardware optimization

b. Unauthorized access to data

c. Network speed enhancement

d. Software development

8. **Which of the following practices is appropriate to password expiration?**

a. Ensuring passwords remain unchanged for long time

b. Requiring regular password updates after a specific time period

c. Storing passwords in a server.

d. Allowing unlimited access with a single password

9. **What is the primary function of firewall in the network security?**

a. Allowing unlimited traffic to pass through the network.

b. Controlling and filtering traffic based on specified criteria.

c. Blocking all types of traffic generally.

d. Encrypting network traffic.

10- **Which one of the following is NOT a type of intrusion detection system?**

a. Network-based intrusion detection system

b. Host-based intrusion detection system

c. File-based intrusion detection system

d. Application-based intrusion detection system

11- **Which protocol typically operates on Port 443, securing web pages over the internet ?**

a. Secure File Transfer Protocol (SFTP)

b. Simple Mail Transfer Protocol (SMTP)

c. Hypertext Transfer Protocol Secure (HTTPS)

d. Secure Shell (SSH)

12- **Which of the following is a primary objective of operating system (OS) hardening?**

a. Minimize system performance

b. Increase the need for backups

c. Decrease the attack surface

d. Developing user interface

Section B [Short Answer Questions] Answer All [5 x 2 = 10 Marks]

B1. Give FOUR main characteristics of the hash function.

Answer: any four (4 x 0.5 = 2 marks)

- Hash functions represent a third cryptography type alongside symmetric and asymmetric cryptography, what we might call keyless cryptography.
- Hash functions referred to as message digests.
- create a largely unique hash value.
- fixed-length hash value.
- Any slight change to the message will change the hash.

B2. Explain any TWO benefits of accountability.

Answer: explain any two (1 mark each)

Deterrence

Accountability can prove to be a great deterrent against misbehavior. If those we monitor are aware of this fact, and it has been communicated to them that there will be penalties for acting against the rules, these individuals may think twice before straying outside the lines. The key to deterrence lies in letting those we want to deter know they will be held accountable for their actions.

Nonrepudiation

Nonrepudiation refers to a situation in which sufficient evidence exists as to prevent an individual from successfully denying that he or she has made a statement, or taken an action such as, system or network logs, use of encryption technologies such as the use of hash functions to digitally sign a communication or a file

IDS and IPS

Intrusion detection systems (IDS) : An IDS performs strictly as a monitoring and alert tool, only notifying us that an attack or undesirable activity is taking place

Intrusion prevention systems (IPS): An IPS, often working from information sent by the IDS, can actually take action based on what is happening in the environment. In response to an attack over the network, an IPS might refuse traffic from the source of the attack.

Admissibility of records

When we seek to introduce records in legal settings, it is often much easier to do so and have them accepted when they are produced from a regulated and consistent tracking system. For example, if we seek to submit digital forensic evidence that we have gathered for use in a court case, the evidence will likely not be admissible to the court unless we can provide a solid and documented chain of custody for said evidence.

B3. Name any FOUR main categories of software development vulnerabilities.

Answer: any four (4 x 0.5 = 2 marks)

- Buffer overflows
- Race conditions
- Input validation Attacks
- Authentication Attacks
- Authorization attacks
- Cryptographic attacks

B4. As per a company's security policy, you must use an access control model. Suppose you have the following subjects and objects which are arranged according to their security level from higher to lower. For each one of the cases below, determine if it applied by the Bell-Lapadula model or Biba Model:

(2 marks)

Answer: (4 x 0.5 = 2 marks)

Subject	**Object**	**Cases**	**Name of the Model**
Ahmed	Excel file	Reem can write to Excel file	Bell-Lapadula
Sali	Word file	Ahmed can read Project file	Bell-Lapadula
Muktar	Project file	Muktar can read Word file	Biba
Reem	Application	Sali can write to Application	Biba

B5. List and explain any TWO types of physical security controls.

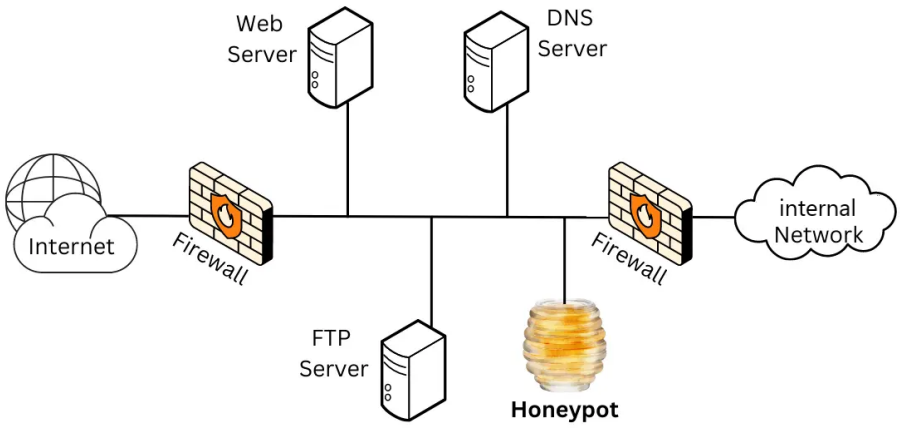
Answer:
Explanation of any two: (1 mark each)
-**Deterrent** controls are designed to discourage those who might seek to violate our security controls from doing so, whether the threat is external or internal. For example, signs in public places that indicate that video monitoring is in place, and the yard signs with alarm company logos that we might find in residential areas.
-**Detective** controls serve to detect and report undesirable events that are taking place. The classic example of a detective control can be found in burglar alarms and physical intrusion detection systems.
- **Preventive** controls are used to physically prevent unauthorized entities from breaching our physical security. An example of preventive security can be found in the simple mechanical lock. Locks are nearly ubiquitous for securing various facilities against unauthorized entry, including businesses, residences, and other locations.

Section C [Long Answer Questions] Answer All [6 x 4 = 24 Marks]

C1. In a corporate environment, there's a robust network infrastructure handling sensitive data transactions. The network architecture below includes various network security mechanisms to ensure data integrity and prevent unauthorized access.

1- **What is a Demilitarized Zone (DMZ)?**

2- **Differentiate between firewall and honeypot.**



Answer: (2 x 2 = 4 marks)

1- (2 marks)
DMZ (demilitarized zone) is generally a combination of a network design feature and a protective device such as a firewall. A layer of protection between the devices, servers, and the Internet, and between the rest of our network and the devices. The need to be exposed to external networks such as the Internet in order to function such as mail servers, proxy servers, software as a service application, and Web servers. we need to ensure their security and the security of the devices on the network behind them.

2- two security mechanisms: (1 mark each)
- **firewall** is a mechanism for maintaining control over the traffic that flows into and out of our network. Firewall might allow or disallow traffic based on the protocol being used, such as allowing Web and e-mail traffic to pass, but blocking everything else.
- **Honeypot** are a somewhat controversial tool in the arsenal of those we can use to improve our network security. A honeypot can detect, monitor, and sometimes tamper with the activities of an attacker. Honeypots are configured to deliberately display vulnerabilities or materials that would make the system attractive to an attacker. One of the interesting things about honeypots is that the vulnerabilities or data that is left out to bait the attacker is entirely false.

C2. An enterprise operates a critical server infrastructure hosting databases, applications, and user data. To ensure comprehensive data recovery in case of a system failure or data loss event, the organization performs regular backups. List and Compare FOUR basic types of enterprise backups.

Types of enterprise backups

Type of Backup	Description	How Used
Full backup	Copies all files	Part of regular backup schedule
Differential backup	Copies all files that have changed since the last full backup	Part of regular backup schedule
Incremental backup	Copies all files that have changed since the last full or incremental backup	Part of regular backup schedule
Copy backup	Copies selected files	Copies files to a new location

Answer: (4 x 1 = 4 marks)

C3. A healthcare organization manages sensitive patient information such as medical records, personal details, and billing information. The organization is concerned about the potential risks and vulnerabilities that could compromise patient privacy.
What are the operations security process steps that must be applied to protect this sensitive information? Explain these steps briefly.

Answer: (0.75 x 4 + 1 x 1 = 4 marks)

The operations security process:

1. Identify the assets. identify what valuable information we have that needs protection.
2. analyze the threats. A threat is something that has the potential to cause us harm. With the list of critical information, we can then begin to look at what harm or financial impact might be caused by critical information being exposed, and who might exploit the exposure.
3. analyze the vulnerabilities that might impact it. Vulnerabilities are weaknesses that can be used to harm us. In the case of analyzing the vulnerabilities in the protections we have put in place for our information assets, we will be looking at how the processes that interact with these assets are normally conducted and where might attack can compromise them.
4. Assess the risk. Assessment of risks in terms of deciding what issues we really need to be concerned about during the operations security process. It is important to note that we need a matching threat and vulnerability to constitute a risk.
5. Countermeasures. Once we have discovered what risks to our critical information might be present, we would then put measures in place to mitigate them. Developing methods of mitigation for those threats and vulnerabilities.

C4. Social engineering encompasses tactics like (pretexting, phishing, and tailgating) to manipulate individuals into giving sensitive information or accessing secure areas. Identify the social engineering tactic used in each scenario below. (8 x 0.5 = 4 marks)

Social Engineering Scenarios	**Social Engineering Tactic**
An email pretending to be from a bank asks for account details.	Phishing
A caller pretends as IT support, asking for login credentials.	Pretexting
A stranger follows closely into a secure facility behind an employee.	Tailgating
Someone claims to be a friend requesting sensitive data.	Pretexting
A fake website mimicking a well-known service asks for passwords.	Phishing
A person calls claiming to be a utility company, asking for personal information.	Pretexting
A person invents a scenario and fake identity to gain access to a restricted area.	Pretexting
A USB drive with malware is left in a visible area.	Phishing

C5. You have a friend, Ahmed, who allows jailbreaking and also downloads applications from untrusted stores in his mobile device. Explain to Ahmed these two security issues and their risks on his mobile device.

Answer: (2 x 2 = 4 marks)

- Jailbreaking, or rooting, a mobile device means modifying it to remove restrictions that the device manufacturer placed on it. This is done to open normally inaccessible features, such as administrative access, and to install apps the device vendor hasn't approved. Mobile devices typically have many layers of security in place, and a persistent jailbreak requires punching a permanent hole all the way through to the kernel that is the core of the operating system. This leaves the device open to malicious apps and outside attacks.
- Malicious apps can compromise the security of mobile devices. Mobile apps often request a great number of privileges when they're installed; often, they can access sensitive information, log into other apps, read email, and use the network connection. You might think you're safe if you download apps from the standard operating system app store, but this isn't the case.

C6. You are a systems administrator responsible for ensuring the security of an organization's computer systems.

What strategies you would use to harden the operating systems against potential cyber threats? Explain any FOUR strategies briefly.

Answer: any four: (4 x 1 = 4 marks)

- **Remove All Unnecessary Software:** Each piece of software installed on our operating system adds to our attack surface. For example, if we are preparing a Web server, we should have the Web server software, and any utilities that deal with the administration and maintenance of the operating system. We have no reason to install anything else if the system is truly going to function solely as a Web server.
- **Remove All Unnecessary Services:** Remove all unessential services in the same vein as removing unneeded software, many operating systems ship with a wide variety of services turned on to provide different functions. Several ports are open as well, running various services. We can use this information as a starting place for closing down undesirable services.
- **Alter Default Accounts:** A common weakness in many operating systems is the use of accounts known to be standard. In many operating systems (as well as some applications), we can find the equivalent of a guest account and an administrator account. We may also find that default accounts are set with a particular password or no password at all. If we allow such accounts to remain on the system with their default settings, we may be leaving the doors that protect access to our system wide open so that attackers can simply stroll right in and make themselves at home.
- **Apply The Principle of Least Privilege:** The principle of least privilege dictates that we only allow a party the absolute minimum permission needed for it to carry out its function.
- **Perform Updates:** Regular and timely updates to our operating systems and applications are critical to maintaining strong security. New attacks are published on a regular basis, and if we do not apply the security patches released by the vendors that manufacture our operating systems and applications, we will likely fall victim very quickly to a large number of well-known attacks.
- **Turn On Logging and Auditing:** We need to be able to keep an accurate and complete record of the important processes and activities that take place on our systems. We want to log significant events such as: the exercise of administrative privileges, users logging in to and out of the system, failing to log in, changes made to the operating system.

End of Exam